

GMX · SECURITY REVIEW

**GMX**

**VesterCap Updates.**

A security review of VesterCap Updates.

| CLIENT | PROJECT           | AUDITORS | AUDIT WINDOW            | FINAL REPORT  |
|--------|-------------------|----------|-------------------------|---------------|
| GMX    | VesterCap Updates | Guardian | July 12 – July 12, 2024 | July 19, 2024 |

§ 00

# Contents.

16 pages — overview, confidence ranking, scope, 7 findings, disclaimer, and about Guardian.

|      |                          |       |
|------|--------------------------|-------|
| § 01 | Overview                 | P. 03 |
| § 02 | Confidence Ranking       | P. 04 |
| § 03 | Scope & Classifications  | P. 05 |
|      | Files in Scope           | P. 06 |
| § 04 | Findings                 | P. 07 |
|      | Main Review · 7 findings | P. 08 |
| § 05 | Disclaimer               | P. 15 |
| § 06 | About Guardian           | P. 16 |

§ 01

Overview.

Guardian reviewed VesterCap Updates across a single review round. The final report includes 1 Critical, 3 Medium, 3 Low findings.

|                         |                                       |
|-------------------------|---------------------------------------|
| AUDIT FIRM              | REPOSITORY                            |
| Guardian                | gmx-io/gmx-contracts                  |
| CLIENT                  | METHODOLOGY                           |
| GMX                     | Smart contract · Manual · Main Review |
| PROJECT                 | MAIN REVIEW COMMIT                    |
| VesterCap Updates       | 8ae995f84f6d                          |
| PREPARED BY             |                                       |
| Guardian                |                                       |
| AUDIT WINDOW            |                                       |
| July 12 – July 12, 2024 |                                       |
| FINAL REPORT            |                                       |
| July 19, 2024           |                                       |

1.1 Confidence Ranking

3 / 5

Moderate Confidence

Guardian assigns a Confidence Ranking of 3 out of 5, combining finding severity, remediation outcome, and the reviewer’s assessment of latent risk. The full scale is on the next page.

|                     |                |                     |                 |                      |
|---------------------|----------------|---------------------|-----------------|----------------------|
| 1                   | 2              | 3                   | 4               | 5                    |
| VERY LOW CONFIDENCE | LOW CONFIDENCE | MODERATE CONFIDENCE | HIGH CONFIDENCE | VERY HIGH CONFIDENCE |

1.2 Findings at a Glance

| SEVERITY                     | TOTAL | PENDING | ACK | PARTIAL | RESOLVED |
|------------------------------|-------|---------|-----|---------|----------|
| <span>■</span> Critical      | 1     | 0       | 1   | 0       | 0        |
| <span>■</span> High          | 0     | 0       | 0   | 0       | 0        |
| <span>■</span> Medium        | 3     | 0       | 3   | 0       | 0        |
| <span>■</span> Low           | 3     | 0       | 3   | 0       | 0        |
| <span>■</span> Informational | 0     | 0       | 0   | 0       | 0        |
| All severities               | 7     | 0       | 7   | 0       | 0        |

## § 02

# Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

| CONFIDENCE RANKING                              | DEFINITION AND RECOMMENDATION                                                                                                                                                                                               | RISK PROFILE                                                                              |
|-------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------|
| <b>5 Very High Confidence</b>                   | Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit. | 0 High/Critical findings and few Low/Medium severity findings.                            |
| <b>4 High Confidence</b>                        | Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.    | 0-1 High/Critical findings per engagement week and little to no Medium severity findings. |
| <b>3 Moderate Confidence</b><br><b>ASSIGNED</b> | Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.                                                            | Some High/Critical findings, with various Medium severity findings.                       |
| <b>2 Low Confidence</b>                         | Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.                                                                     | Over 6 High and Critical findings across the engagement.                                  |
| <b>1 Very Low Confidence</b>                    | The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.                                                                           | Over 12 High and Critical findings across the engagement.                                 |

## § 03

# Scope & Classifications.

Guardian reviewed VesterCap Updates in `gmx-io/gmx-contracts`.

## 3.1 Severity Matrix

|            | IMP · HIGH | IMP · MED | IMP · LOW |
|------------|------------|-----------|-----------|
| LIK · HIGH | Critical   | High      | Medium    |
| LIK · MED  | High       | Medium    | Low       |
| LIK · LOW  | Medium     | Low       | Low       |

### IMPACT · HIGH

Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

### IMPACT · MEDIUM

Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

### IMPACT · LOW

Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

### LIKELIHOOD · HIGH

Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

### LIKELIHOOD · MEDIUM

Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

### LIKELIHOOD · LOW

Unlikely to ever occur in production.

# Files in Scope.

| FILE                             | NSLOC | TOTAL |
|----------------------------------|-------|-------|
| No files were recorded in scope. |       |       |

## § 04

# Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in.

| ID          | TITLE                                                 | CATEGORY      | SEVERITY | STATUS       | PAGE  |
|-------------|-------------------------------------------------------|---------------|----------|--------------|-------|
| MAIN REVIEW |                                                       |               |          |              |       |
| C-01        | Duplicate esGMX Rewards By Transferring Accounts      | Gaming        | CRITICAL | ACKNOWLEDGED | p. 8  |
| M-01        | Users Vest Without Pairing Backed sbfGMX              | Gaming        | MEDIUM   | ACKNOWLEDGED | p. 9  |
| M-02        | Bonus esGMX Require Less Paired Tokens                | Logical Error | MEDIUM   | ACKNOWLEDGED | p. 10 |
| M-03        | Vester Withdrawals May Be DoS'd                       | DoS           | MEDIUM   | ACKNOWLEDGED | p. 11 |
| L-01        | New VesterCap Configurations                          | Configuration | LOW      | ACKNOWLEDGED | p. 12 |
| L-02        | Users With Reserved sbfGMX May Not Be Able To Unstake | Logical Error | LOW      | ACKNOWLEDGED | p. 13 |
| L-03        | Incorrect Error Message                               | Documentation | LOW      | ACKNOWLEDGED | p. 14 |

CRITICAL **C-01**

ACKNOWLEDGED

# Duplicate esGMX Rewards By Transferring Accounts

|          |             |
|----------|-------------|
| CATEGORY | Gaming      |
| LOCATION | Global      |
| REVIEW   | Main Review |

## — DESCRIPTION

esGMX rewards may be duplicated by transferring bnGMX from accounts that have already been processed by the `updateBnGmxForAccount` function to accounts that have yet to be processed.

For example:

- Account A has accumulated X bnGMX sitting in it's balance after the compound
- Account B is empty
- Account A is processed and receives esGMX rewards for X bnGMX
- Account A transfers their account to Account B
- Account B is processed and receives esGMX rewards for X bnGMX

Rewards are granted for 2X bnGMX, though the owner of Account A & B only had X bnGMX.

## — RECOMMENDATION

Consider burning the bnGMX, unclaimed bnGMX, and reserved for vesting bnGMX for an account after it is processed.

PROOF OF CONCEPT <https://github.com/GuardianAudits/VesterCapPoCs>

## — RESOLUTION

Status: Acknowledged.

MEDIUM **M-01**

ACKNOWLEDGED

# Users Vest Without Pairing Backed sbfGMX

CATEGORY Gaming  
LOCATION Global  
REVIEW Main Review

## — DESCRIPTION

Accounts where the vested esGMX amount is paired with sbfGMX which is backed by bnGMX will effectively receive pair-free vesting because the bnGMX is removed for them while their vest is allowed to continue.

As a result users may begin vests with sbfGMX which is backed by bnGMX so that they can intentionally receive pair-free vesting.

## — RECOMMENDATION

Do not announce when this migration will take place, and do not emphasize the details of the unreserving so that it is less likely to be gamed. Additionally, consider adding a disincentive such as a reward deduction for accounts which would receive an effectively pair-free vest.

## — RESOLUTION

Status: Acknowledged.

MEDIUM **M-02**

ACKNOWLEDGED

## Bonus esGMX Require Less Paired Tokens

CATEGORY Logical Error  
LOCATION VesterCap.sol  
REVIEW Main Review

### — DESCRIPTION

Escrowed GMX (esGMX) tokens can be converted into GMX tokens through vesting.

When vesting is initiated, the average amount of GMX tokens that was used to earn the esGMX rewards will be reserved.

The update aims to mint 1 esGMX for every 25 bnGMX, and then a user can vest those esGMX. However, the newly minted esGMX did not originate from the stakedGMXTracker, and are not considered in the averageStakedAmounts.

Consequently, less pair tokens are taken from the user for their vests than an account that would've vest the same amount of esGMX but earned them through the stakedGmxTracker.

### — RECOMMENDATION

Consider making up for this deficit by increasing the `transferredAverageStakedAmounts` to maintain the existing ratio of `averageStakedAmounts / maxVestableAmount` for pair tokens.

### — RESOLUTION

Status: Acknowledged.

MEDIUM **M-03**

ACKNOWLEDGED

# Vester Withdrawals May Be DoS'd

|          |             |
|----------|-------------|
| CATEGORY | DoS         |
| LOCATION | Global      |
| REVIEW   | Main Review |

## DESCRIPTION

When the function `updateBnGmxForAccounts` is called, the tracker tokens are transferred directly to the `_account` without updating the pair amounts in the Vester. As a result, there is a divergence between the Vester's internal balance and its true pair balance.

The `syncFeeGmxTrackerBalance` is intended to sync these balances as soon as one of these accounts withdraws their paired tokens from the vester. This will correctly fix the gap in the vester contract, however when the amount of sbfGMX that is reserved and backed by bnGMX exceeds that of sbfGMX reserved and backed by non-bnGMX these users may be unable to withdraw from the vester in the first place.

For example:

- User A holds 5 sbfGMX backed by staked GMX in the vester
- User B holds 8 sbfGMX backed by bnGMX and 2 sbfGMX backed by staked GMX in the vester
- User B's 8 sbfGMX backed by bnGMX is unreserved from the vester
- The vester's sbfGMX balance is reduced to 7
- User A may withdraw their sbfGMX tokens and leave the vester balance at 3
- User B can not withdraw their paired tokens either before nor after User A withdraws as the vester does not have sufficient balance

## RECOMMENDATION

In anticipation of the migration, consider minting additional sbfGMX to the vester contract so that it can cover any deficit that may be created and ensure that users can rightfully withdraw their sbfGMX.

## RESOLUTION

Status: Acknowledged.

LOW **L-01**

ACKNOWLEDGED

# New VesterCap Configurations

|          |               |
|----------|---------------|
| CATEGORY | Configuration |
| LOCATION | Global        |
| REVIEW   | Main Review   |

## — DESCRIPTION

Currently in the tests and in the deployVesterCap.js file, the maxBoostBasisPoints are configured to 20\_000. However the new vester cap deployment should utilize a maxBoostBasisPoints of 0 as no bnGMX may be staked.

## — RECOMMENDATION

When updating the scripts to deploy the new version of the VesterCap contract, be sure to assign the maxBoostBasisPoints to 0.

## — RESOLUTION

Status: Acknowledged.

LOW **L-02**

ACKNOWLEDGED

# Users With Reserved sbfGMX May Not Be Able To Unstake

|          |                         |
|----------|-------------------------|
| CATEGORY | Logical Error           |
| LOCATION | RewardRouterV2.sol: 499 |
| REVIEW   | Main Review             |

## — DESCRIPTION

In the `_unstakeGMX` function a portion of the account's staked `bnGMX` balance is burned as a punishment for unstaking.

However the account may not hold the required `sbfGMX` amount in order for the call to `unstakeForAccount` for the `reductionAmount` to work.

As a result accounts which have at least a portion of their reserved `sbfGMX` backed by staked `bnGMX` will be unable to unstake all of their `GMX` or `esGMX` until the vest is completed or withdrawn.

For example:

- Account A has 9 `sbfGMX` backed by staked `bnGMX` and 1 `sbfGMX` backed by `GMX`
- Account A has 9 `sbfGMX` reserved in the vester contract
- Account A unstakes their 1 `sbfGMX` which is not reserved
- The `reductionAmount` is 0.9
- `unstakeForAccount` is called but it reverts as the account has no more remaining `sbfGMX`

As a result the user cannot unstake their `GMX` until the vest is over or withdrawn.

## — RECOMMENDATION

This behavior is resolved by the `VesterCap` functionality once it has been carried out. In the meantime be aware of this unexpected behavior.

## — RESOLUTION

Status: Acknowledged.

LOW **L-03**

ACKNOWLEDGED

## Incorrect Error Message

|          |                             |
|----------|-----------------------------|
| CATEGORY | Documentation               |
| LOCATION | RewardRouterV2.sol: 409-410 |
| REVIEW   | Main Review                 |

### — DESCRIPTION

"gmxVester" is used as the prefix in `_validateReceiver` when the `glpVester` staked amounts are validated.

### — RECOMMENDATION

Consider changing the prefix to `glpVester`.

### — RESOLUTION

Status: Acknowledged.

## § 05

# Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

## § 06

# About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

**\$45B+**DIGITAL ASSETS UNDER  
REVIEW**200+**

ENGAGEMENTS COMPLETED

**500+**CRITICAL & HIGH FINDINGS  
REPORTED

Reach us at [audits@guardianaudits.com](mailto:audits@guardianaudits.com).